2015 Italian Cyber Security Report

Un Framework Nazionale per la Cyber Security

Roberto Baldoni
@robertobaldoni

Cyber Intelligence and Information Security Center
Sapienza Università di Roma

cini
Cyber Security National Lab

IoT

Big Data

Robotics

Industry 4.0

Smart Cities

Drones

Digital Currency

Agricolture 4.0

Cyber Intelligence and Information Security Center
Sapienza Università di Roma

cini
Cyber Security National Lab

Il concetto di velocità

- La trasformazione economica sarà sempre più veloce, inarrestabile, implacabile cambierà il lavoro, uccidendo vecchi posti e creandone di nuovi

- Cambierà pesantemente gli equilibri tra stati, tra aziende e tra stati e aziende

Il concetto di velocità

- La trasformazione
-

di

tra

Economia Cyberspace

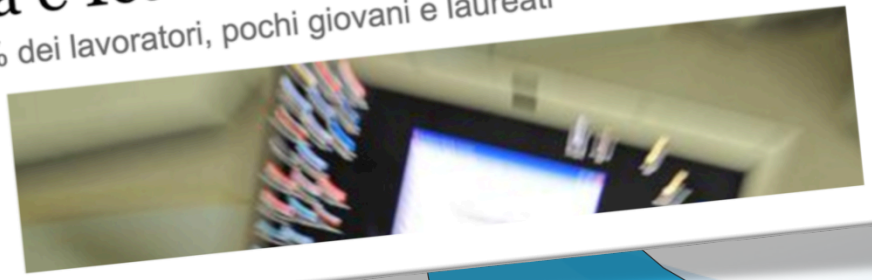
Chi non saprà intercettare questa rivoluzione diventerà terzo mondo del terzo millennio

Cyber Intelligence and Information Security Center
Sapienza Università di Roma
cini Cyber Security National Lab

ANSA.it › Tecnologia › Tlc › Italia tra ultimi paesi Ue per esperti informatica e Ict

Italia tra ultimi paesi Ue per esperti informatica e Ict

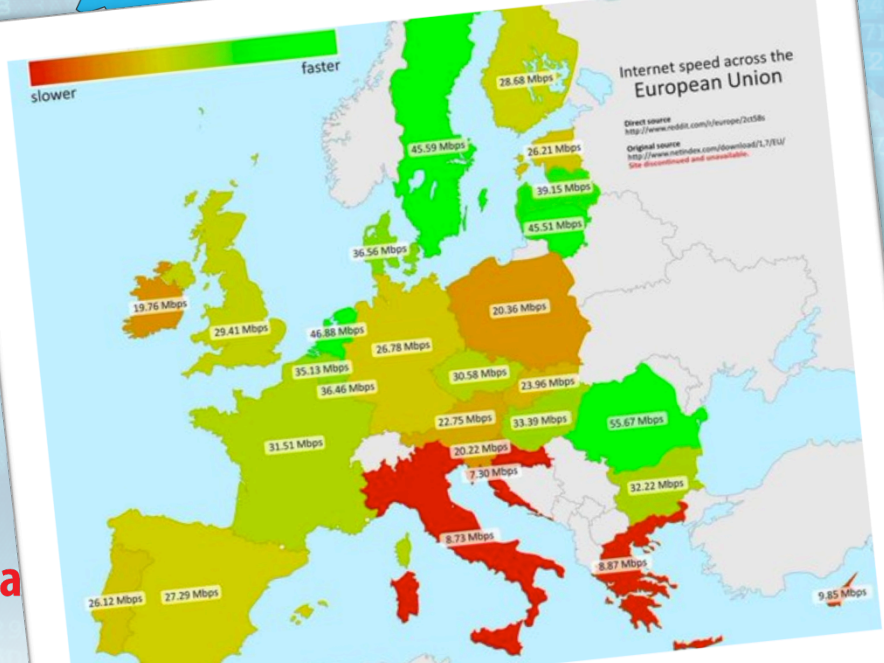
Eurostat, sono il 2,5% dei lavoratori, pochi giovani e laureati



Redazione ANSA

BRUXELLES

22 gennaio 2016
15:19
NEWS



CYBER INTELLIGENCE AND INFORMATION SECURITY CENTER

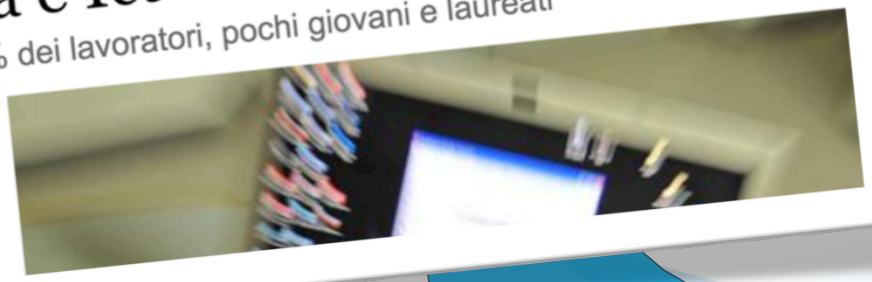
SAPIENZA UNIVERSITÀ DI ROMA

cini Cyber Security Na

ANSA.it › Tecnologia › Tlc › Italia tra ultimi paesi Ue per esperti informatica e Ict

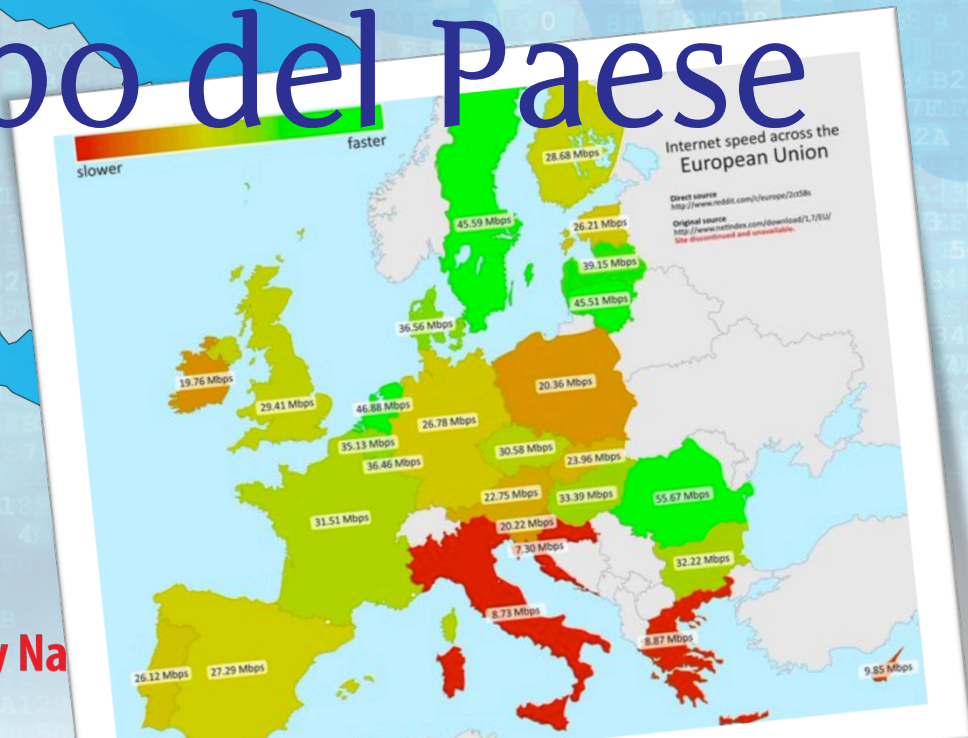
Italia tra ultimi paesi Ue per esperti informatica e Ict

Eurostat, sono il 2,5% dei lavoratori, pochi giovani e laureati



Redazione ANSA
BRUXELLES
22 gennaio 2016
15:19
NEWS

Agenda Digitale al centro dello sviluppo del Paese



Cyber Intelligence and Information Security Center
Sapienza Università di Roma

cini Cyber Security Na

Economia Cyberspace

Protezione del cyberspace condizione necessaria per la prosperità economica

Cyber Intelligence and Information Security Center

Sapienza Università di Roma

cini Cyber Security National Lab

Unicità del Cyberspace

- Non esiste divisione tra pubblico e privato, tra militare e civile. Un ambiente dove tutto è duale!
- Vulnerabilità non numerabili, attacchi in costante aumento per precisione e potenza
- Nessuno può pensare di gestire questa complessità in isolamento

Economia
Cyberspace

Risposta come sistema paese alla protezione del cyberspace nazionale

Cyber Intelligence and Information Security Center
Sapienza Università di Roma
cini Cyber Security National Lab

Economia

Cyberspace

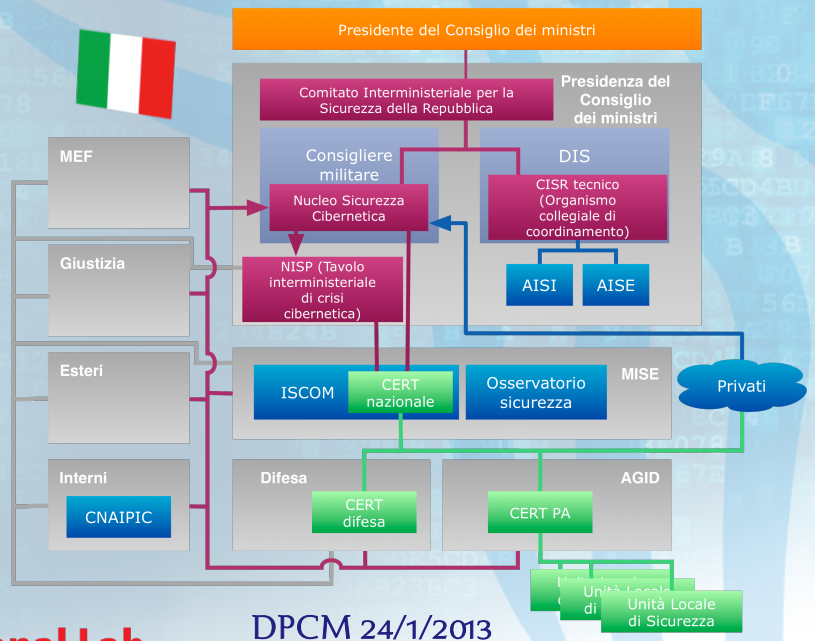
Risposta come sistema paese alla protezione del cyberspace

Cyber Intelligence and Information Security Center

Sapienza Università di Roma

Architettura Nazionale di Cyber Security

- Asset nazionale strategico
- Deve acquisire velocità!



DPCM 24/1/2013

Cyber Intelligence and Information Security Center

Sapienza Università di Roma

cini Cyber Security National Lab

Ricerca e Privato devono aiutare a dare velocità all'architettura nazionale cyber

Cyber Intelligence and Information Security Center
Sapienza Università di Roma
cini Cyber Security National Lab

PPP innovative acceleratore del piano strategico nazionale di cyber security

Ricerca

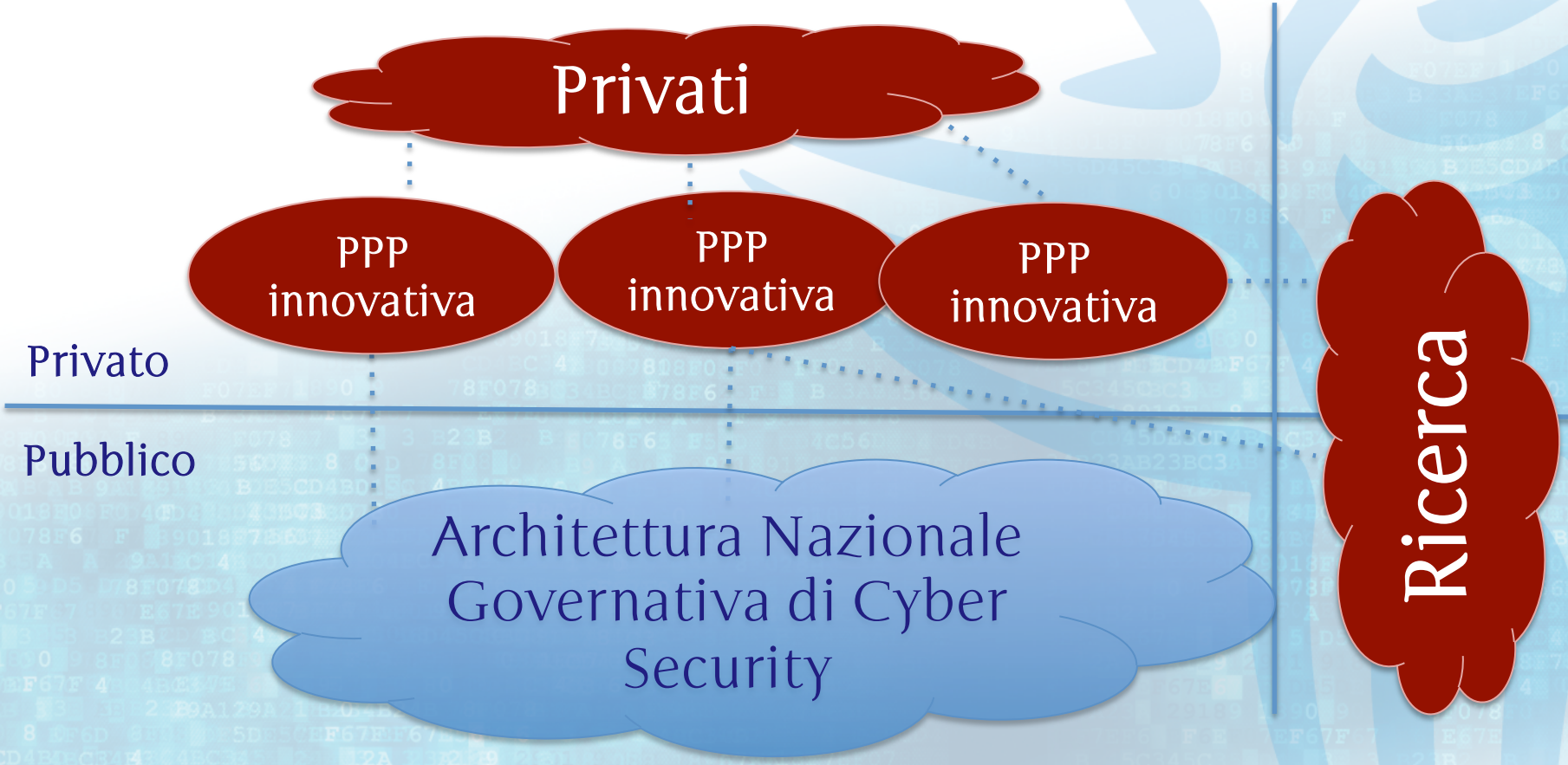
Progetti Strategici

Startup

Servizi

Cyber Intelligence and Information Security Center
Sapienza Università di Roma
cini Cyber Security National Lab

"The Italian way" per accelerare



Il "Framework Nazionale per la Cyber Security" è uno strumento definito in un contesto PPP che serve per aumentare la velocità di implementazione del piano strategico nazionale

Cyber Intelligence and Information Security Center
Sapienza Università di Roma
cini Cyber Security National Lab

Realizzato da:

Cyber Intelligence and Information Security Center

Sapienza Università di Roma

cini Cyber Security National Lab

Tavolo di lavoro:

AON

Deloitte.

Enel

eni

hermesbay

KPMG

INTELLIUM

In collaborazione con:

Agenzia per l'Italia Digitale
Presidenza del Consiglio dei Ministri

GARANTE
PER LA PROTEZIONE
DEI DATI PERSONALI

Ministero dello Sviluppo Economico

COMPUTER EMERGENCY RESPONSE TEAM
PUBBLICA AMMINISTRAZIONE
CERT - PA
Agenzia per l'Italia Digitale
Presidenza del Consiglio dei Ministri

CERT nazionale Italia

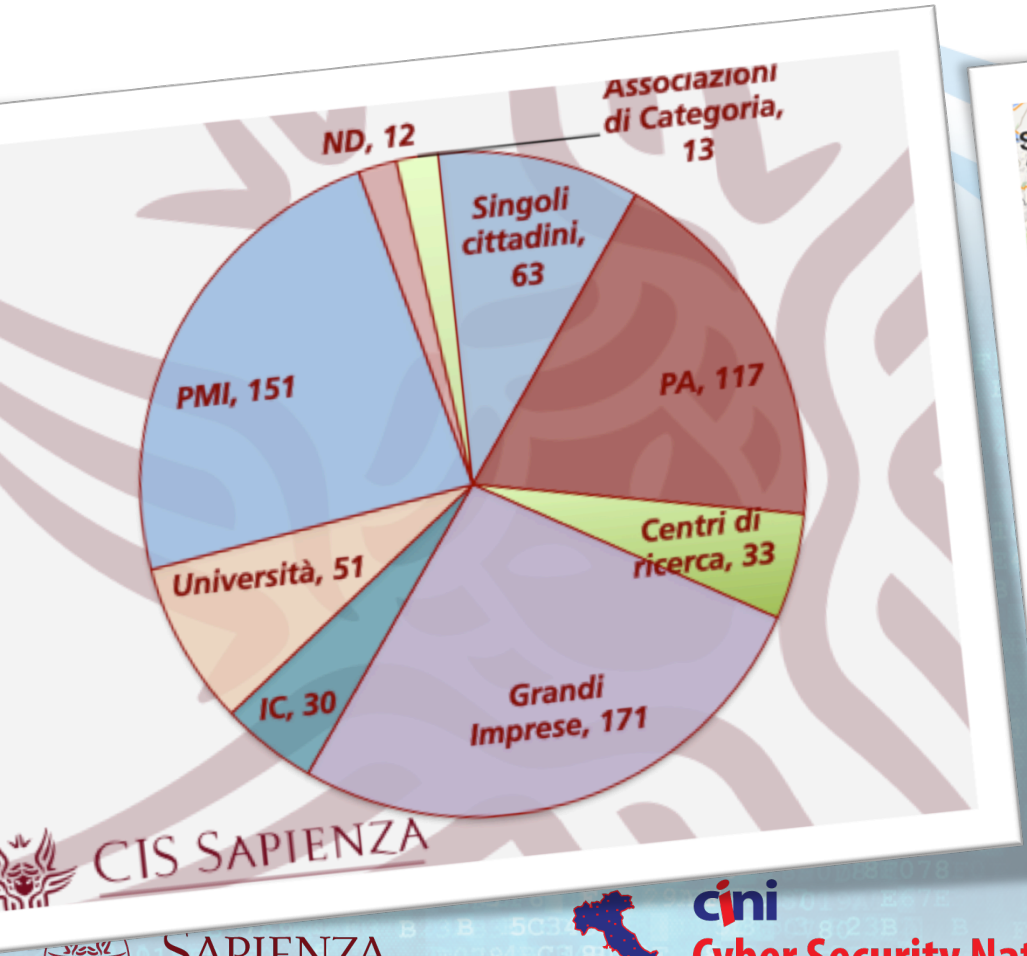
e:

Microsoft

pwc

Con il supporto del Dipartimento delle Informazioni per la Sicurezza della PresidenzaDel Consiglio dei ministri

>1000 Registrazioni alla consultazione pubblica >500 emendamenti ricevuti



Framework Nazionale per la Cyber Security: obiettivi

- Rischio cyber come un rischio economico aziendale (parte del risk management e del DNA aziendale)
- Portare il rischio cyber nei CDA (non rimanere confinato nell'ambiente tecnico)
- Considerare lo scenario economico italiano (dominato dalla presenza di PMI) ed i diversi settori produttivi
- Non reinventare la ruota (il framework non è tecnologia è metodologia)

I **PARTE I - Il Framework Nazionale**

2 La necessità di un Framework Nazionale 9
2.1 I vantaggi per il panorama italiano: PMI, Grandi Imprese e regolatori di settore 10
2.2 Il Framework e la gestione del rischio cyber 11
2.3 I vantaggi per il sistema paese: verso una international due diligence 12

3 I concetti di base 13
3.1 Framework Core, Profile e Implementation Tier 14
3.2 I livelli di priorità 15
3.3 I livelli di maturità 17
3.4 Come contestualizzare il Framework 19
3.5 Come aggiornare il Framework 20

4 Linee guida per l'applicazione del Framework 23
4.1 Piccole-Medie Imprese 23
4.2 Grandi Imprese 25
4.3 Infrastrutture Critiche 27
4.4 Regolatori di settore 27

II **PARTE II - Documenti di supporto al Framework**

5 Framework Core 31

6 Una contestualizzazione del Framework per PMI 41
6.1 Selezione delle Subcategory 41
6.2 Livelli di priorità 42
6.3 Livelli di maturità 52
6.4 Guida all'implementazione delle Subcategory a priorità alta 58

7 Raccomandazioni per le Grandi Imprese 69
7.1 Il ruolo del top management nella gestione del rischio cyber 70
7.2 Il processo di cyber security risk management 73
7.3 Computer Emergency Readiness Team (CERT) 76

III **PARTE III - Aspetti legati al contesto di applicazione**

8 L'Enterprise Risk Management: il contesto di riferimento 81
8.1 L'analisi del rischio 82
8.2 I vantaggi dell'applicazione di un processo di ERM 85

9 Le polizze cyber risk 87
9.1 Percezione del rischio e diffusione delle polizze cyber 89
9.2 Guida all'implementazione di una copertura assicurativa cyber risk 91

10 Aspetti di privacy legati al Framework 93
10.1 Il Codice della Privacy 93
10.2 Informazioni classificate e segreto di Stato 97

11 Regolatori di settore 99
11.1 Pubbliche Amministrazioni 99
11.2 Settore bancario e finanziario 101
11.3 Aziende quotate in mercati regolamentati 103

Cyber Intelligence and Information Security Center
Sapienza Università di Roma
cini Cyber Security National Lab

Il framework nazionale è uno strumento (ad adozione volontaria) di auto-analisi di una organizzazione

Cyber Intelligence and Information Security Center
Sapienza Università di Roma
cini Cyber Security National Lab

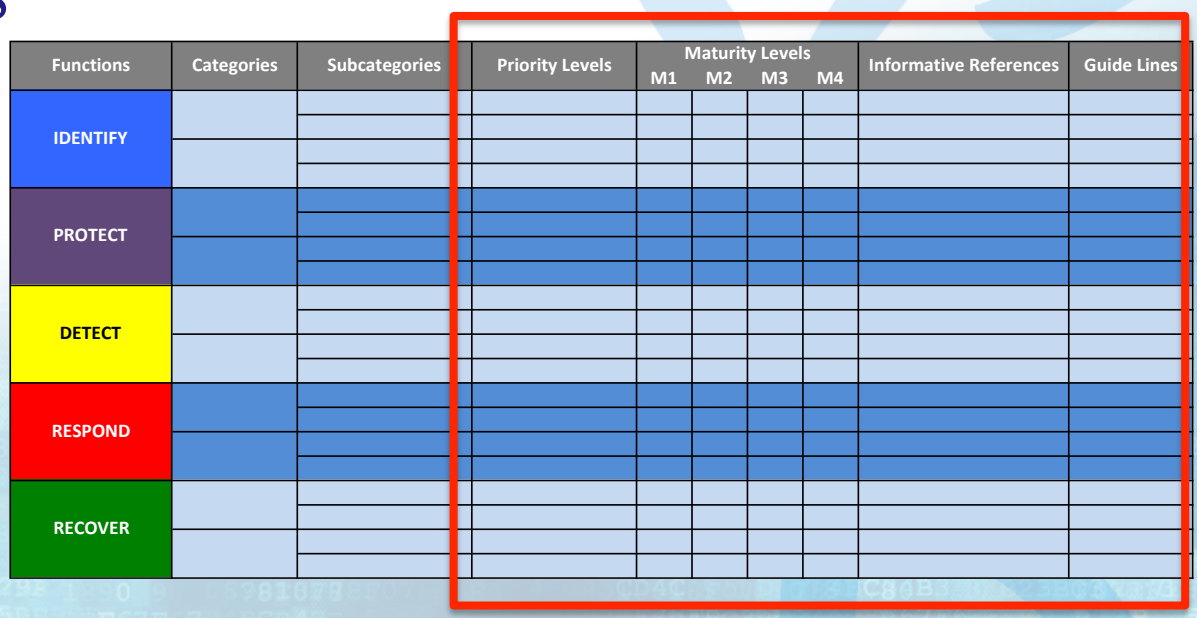
NIST Framework for Improving Critical Infrastructure Cybersecurity

- Implementation tiers
- Framework core
- Profiles

Functions	Categories	Subcategories	Informative References
IDENTIFY			
PROTECT			
DETECT			
RESPOND			
RECOVER			

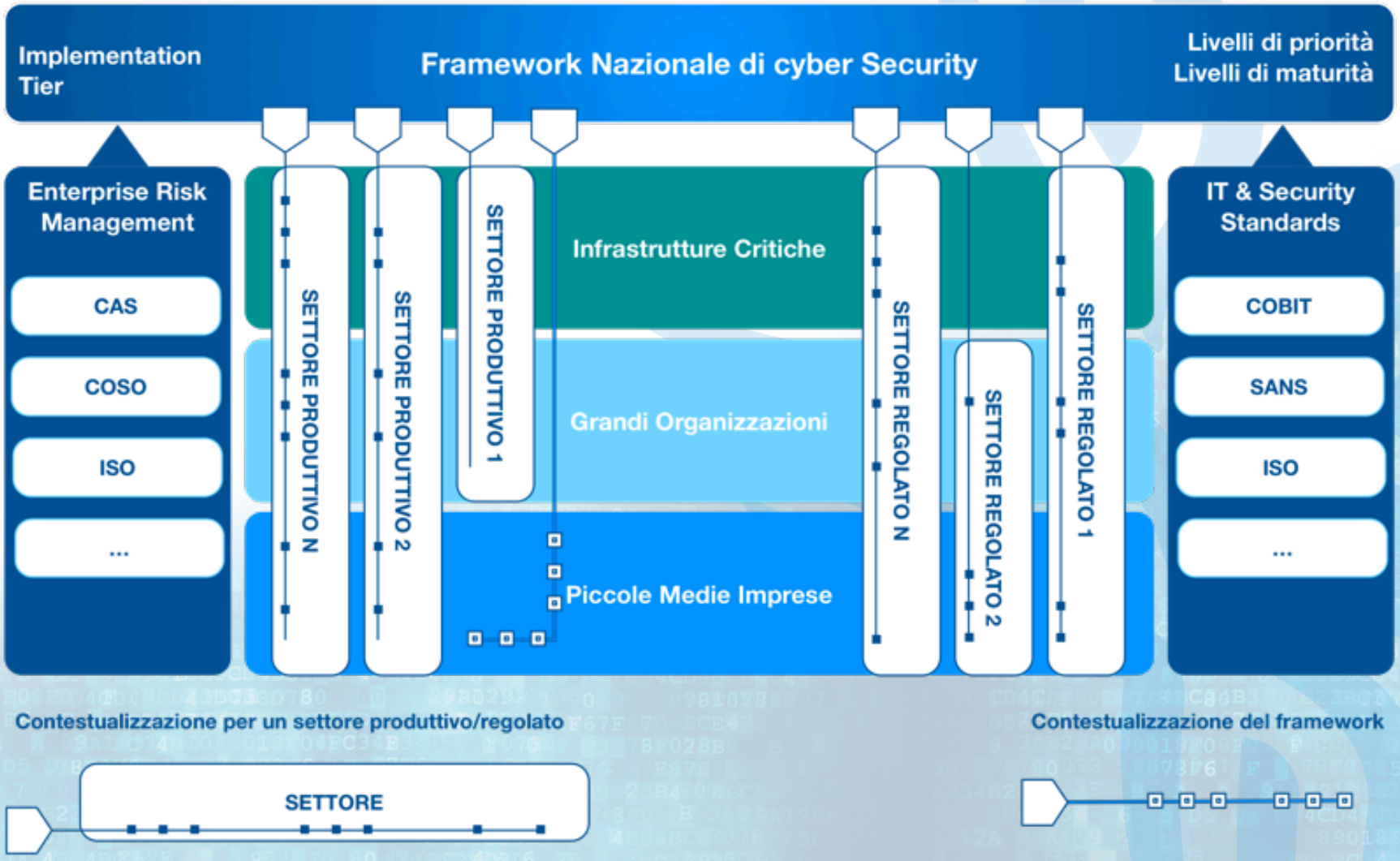
Framework Nazionale per la Cybersecurity

- Implementation tiers
- Framework core
- Profiles



Abbiamo Aggiunto:

- Livelli Priorità
- Livelli di Maturità
- Contestualizzazioni
- Linee Guida


Implementation Tier
Framework Nazionale di cyber Security
Livelli di priorità
Livelli di maturità
Enterprise Risk Management
CAS
COSO
ISO
...
SETTORE PRODUTTIVO N
SETTORE PRODUTTIVO 2
SETTORE PRODUTTIVO 1
Infrastrutture Critiche
Grandi Organizzazioni
Piccole Medie Imprese
SETTORE REGOLATO N
SETTORE REGOLATO 2
SETTORE REGOLATO 1
IT & Security Standards
COBIT
SANS
ISO
...
Contestualizzazione per un settore produttivo/regolato
SETTORE
Contestualizzazione del framework

Framework Nazionale per la Cyber Security: Vantaggi grandi imprese

- Top Management Awareness
- Un aiuto a definire piani a risorse sostenibili di gestione del rischio cyber (anche attraverso lo strumento assicurativo)
- Gestione della catena di approvvigionamento
- Un aiuto nell'approntare un processo evoluto di gestione del rischio cyber

Framework Nazionale per la Cyber Security: Vantaggi grandi imprese

– To
– Un
ge
str
– Ge
– Un
gest

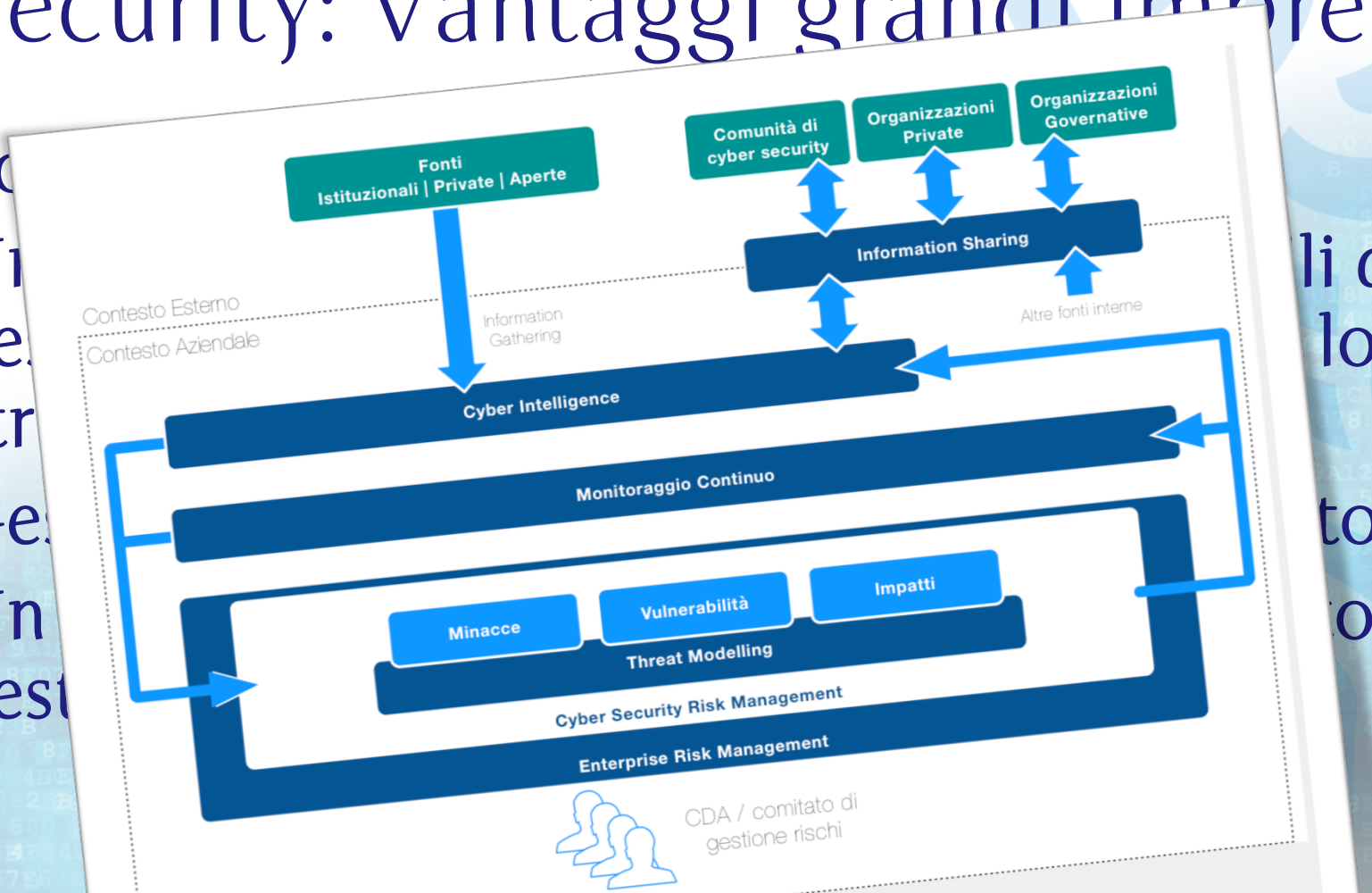


Figura 7.2: Un approccio evoluto alla gestione del rischio cyber.

li di
lo
to
o di

Framework come insieme di pratiche di un Duty-of-care per mitigare rischi cyber

Cyber Intelligence and Information Security Center

Sapienza Università di Roma

cini Cyber Security National Lab

Framework Nazionale per la Cyber Security: Vantaggi per le PMI

- Una contestualizzazione del framework dedicata a loro
  - Livelli di priorità
  - Livelli di maturità
  - Guida all'implementazione dei controlli a priorità alta
- 20 quick-win
- Come adottare il framework

Framework Nazionale per la Cyber Security: Vantaggi per la nazione

- Fornire una quadro comune a diverse autorità che regolamentano il settore in modo da regolamentare in modo coerente e.g.,Garante Privacy, AGID, PCM, ecc.)
- International due diligence

Capitolo 6. Una contestualizzazione del Framework per PMI

Function	Category	Subcategory	Priorità	Informative References
PROTECT (PR)		PR.AT-4: I dirigenti ed i vertici aziendali comprendono ruoli e responsabilità	ALTA	· CCS CSC 9 · COBIT 5 APO07.03 · ISA 62443-2-1:2009 4.3.2.4.2 · ISO/IEC 27001:2013 A.6.1.1, A.7.2.2, · NIST SP 800-53 Rev. 4 AT-3, PM-13
		PR.AT-5: Il personale addetto alla sicurezza fisica e delle informazioni comprende i ruoli e le responsabilità	MEDIA	· CCS CSC 9 · COBIT 5 APO07.03 · ISA 62443-2-1:2009 4.3.2.4.2 · ISO/IEC 27001:2013 A.6.1.1, A.7.2.2, · NIST SP 800-53 Rev. 4 AT-3, PM-13
	Data Security (PR.DS): I dati sono memorizzati e gestiti in accordo alla strategia di gestione del rischio dell'organizzazione, al fine di garantire l'integrità, la confidenzialità e la disponibilità delle informazioni.	PR.DS-1: I dati e le informazioni memorizzate sono protette	MEDIA	· CCS CSC 17 · COBIT 5 APO01.06, BAI02.01, BAI06.01, DSS06.06 · ISA 62443-3-3:2013 SR 3.4, SR 4.1 · ISO/IEC 27001:2013 A.8.2.3 · NIST SP 800-53 Rev. 4 SC-28 · **Da eseguirsi per coloro che trattano informazioni classificate ai sensi del DPCM 6 novembre 2015 e dei relativi decreti n. 4/2015 e n.5/2015** · **Obbligatoria in caso di trattamento di dati personali mediante strumenti elettronici (ai sensi dell'All. B) D. Lgs. 196/2003 Regole 16,17, 20)**
		PR.DS-2: I dati sono protetti durante la trasmissione	BASSA	· CCS CSC 17 · COBIT 5 APO01.06, DSS06.06 · ISA 62443-3-3:2013 SR 3.1, SR 3.8, SR 4.1, SR 4.2 · ISO/IEC 27001:2013 A.8.2.3, A.13.1.1, A.13.2.1, A.13.2.3, A.14.1.2, A.14.1.3 · NIST SP 800-53 Rev. 4 SC-8 · **Obbligatoria in caso di trattamento di dati personali mediante strumenti elettronici (ai sensi dell'All. B) D. Lgs. 196/2003)**
		PR.DS-3: Il trasferimento fisico, la rimozione e la distruzione dei dispositivi atti alla memorizzazione di dati sono gestiti attraverso un processo formale	NON SELEZIONATA	· COBIT 5 BAI09.03 · ISA 62443-2-1:2009 4. 4.3.3.3.9, 4.3.4.4.1 · ISA 62443-3-3:2013 SR 4.2 · ISO/IEC 27001:2013 A.8.2.3, A.8.3.1, A.8.3.2, A.8.3.3, A.11.2.7 · NIST SP 800-53 Rev. 4 CM-8, MP-6, PE-16
		PR.DS-4: I sistemi hanno adeguate risorse a disposione per poter garantire la disponibilità	MEDIA	· COBIT 5 APO13.01 · ISA 62443-3-3:2013 SR 7.1, SR 7.2 · ISO/IEC 27001:2013 A.12.3.1 · NIST SP 800-53 Rev. 4 AU-4, CP-2, SC-5
		PR.DS-5: Sono implementate tecniche di protezione (es. controllo di accesso) contro la sottrazione dei dati (data leak).	BASSA	· CCS CSC 17 · COBIT 5 APO01.06 · ISA 62443-3-3:2013 SR 5.2 · ISO/IEC 27001:2013 A.6.1.2, A.7.1.1, A.7.1.2, A.7.3.1, A.8.2.2, A.8.2.3, A.9.1.1, A.9.1.2, A.9.2.3, A.9.4.1, A.9.4.4, A.9.4.5, A.13.1.3, A.13.2.1, A.13.2.3, A.13.2.4, A.14.1.2, A.14.1.3 · NIST SP 800-53 Rev. 4 AC-4, AC-5, AC-6, PE-19, PS-3, PS-6, SC-7, SC-8, SC-13, SC-31, SI-4 · **Obbligatoria in caso di trattamento di dati personali mediante strumenti elettronici (ai sensi dell'All. B) D. Lgs. 196/2003)**
		PR.DS-6: Vengono implementate tecniche di controllo dell'integrità dei dati per verificare l'autenticità di software, firmware e delle	BASSA	· ISA 62443-3-3:2013 SR 3.1, SR 3.3, SR 3.4, SR 3.8 · ISO/IEC 27001:2013 A.12.2.1, A.12.5.1, A.14.1.2, A.14.1.3 · NIST SP 800-53 Rev. 4 SI-7
		PR.DS-7: Gli ambienti di sviluppo e test sono		· COBIT 5 BAI07.04

Capitolo 6. Una contestualizzazione del Framework per PMI

Function	Subcategory	Rif.Guida	Livello 1	Livello 2	Livello 3
IDENTIFY (ID)	ID.AM-1: Sono censiti i sistemi e gli apparati fisici in uso nell'organizzazione	Tabella 6.1: Identificazione degli Asset (IA)	Il censimento, la classificazione e l'aggiornamento degli asset (intesi come informazioni, applicazioni, sistemi ed apparati presenti) avviene in modalità per lo più manuale secondo un processo definito e controllato	Il censimento, la classificazione e l'aggiornamento degli asset avviene attraverso un sistema parzialmente automatico, che consenta di automatizzare almeno la fase di "discovery" dei sistemi connessi in rete, rilevando le principali caratteristiche degli stessi (caratteristiche hardware, software installati, configurazioni adottate, ecc.) e registrando l'inventario ottenuto in un repository centralizzato	Il censimento, la classificazione e l'aggiornamento degli asset avviene attraverso un sistema completamente automatico, che consenta di gestire l'intero ciclo di vita di un asset (identificazione, assegnazione, cambiamenti di stato, dismissioni)
	ID.AM-2: Sono censite le piattaforme e le applicazioni software in uso nell'organizzazione	Tabella 6.1: Identificazione degli Asset (IA)	Vedi ID.AM-1	Vedi ID.AM-1	Vedi ID.AM-1
	ID.AM-6: Sono definiti e resi noti ruoli e responsabilità inerenti la cybersecurity per tutto il personale e per eventuali terze parti rilevanti (es. fornitori, clienti, partner)	Tabella 6.2: Assegnazione Responsabilità (AR)	La Proprietà e/o il Vertice Aziendale nomina il referente per la Cyber Security, definendo formalmente le attività in carico. Formalizza inoltre il disciplinare tecnico per l'utilizzo consono delle informazioni e degli strumenti informatici da parte di tutte le parti interessate (e.g. dipendenti, consulenti, terze parti)	Deve essere predisposto un documento di Politica Aziendale per la Cyber Security che definisca e formalizzi chiaramente i ruoli, le responsabilità e le attività richieste a ciascuna parte coinvolta a vario titolo nella gestione della Cyber Security (dipendenti, consulenti, terze parti), comunicando chiaramente l'impegno della Proprietà o dei Vertici Aziendali rispetto a tali necessità	N/A
	ID.GV-3: I requisiti legali in materia di cybersecurity, con l'inclusione degli obblighi riguardanti la privacy e le libertà civili, sono compresi e gestiti	Tabella 6.3: Conformità a leggi e regolamenti (CLR)	La conformità a leggi e regolamenti è raggiunta e verificata, anche ricorrendo a specialisti e fornitori esterni, ove ritenuto necessario, in grado di agevolare l'individuazione e la gestione degli aspetti normativi e di conformità, soprattutto quando direttamente o indirettamente connessi con gli aspetti di Cyber Security	N/A	N/A

Profilo cyber attuale

Profilo cyber target

Chi può contestualizzare il framework

- La singola azienda. Questo prevede che l'azienda sia abbastanza matura da poter gestire un modello di gestione del rischio associato;
- Una associazione di settore produttivo, per rendere la contestualizzazione del Framework disponibile a tutte le aziende del settore;
- Un regolatore di settore per rendere la contestualizzazione del Framework disponibile a tutte le organizzazioni del settore;
- Un qualsiasi attore che definisce una contestualizzazione del Framework in funzione di una o più caratteristiche che accomunano delle aziende, come ad esempio, dislocazione geografica, dimensione, tipologia del personale ecc.

Il Framework come lingua comune intersettoriale della cyber

Cyber Intelligence and Information Security Center
Sapienza Università di Roma
cini Cyber Security National Lab

III PARTE III - Aspetti legati al contesto di applicazione

8 L'Enterprise Risk Management: il contesto di riferimento 81
8.1 L'analisi del rischio 82
8.2 I vantaggi dell'applicazione di un processo di ERM 85

9 Le polizze cyber risk 87
9.1 Percezione del rischio e diffusione delle polizze cyber 89
9.2 Guida all'implementazione di una copertura assicurativa cyber risk 91

10 Aspetti di privacy legati al Framework 93
10.1 Il Codice della Privacy 93
10.2 Informazioni classificate e segreto di Stato 97

11 Regolatori di settore 99
11.1 Pubbliche Amministrazioni 99
11.2 Settore bancario e finanziario 101
11.3 Aziende quotate in mercati regolamentati 103

Cyber Intelligence and Information Security Center
Sapienza Università di Roma
cini Cyber Security National Lab

Framework come fattore di accelerazione

- Per la messa in sicurezza del cyberspace nazionale attraverso approccio intersettoriale
- Per la creazione di competenze domestiche
- Per il rafforzamento del mercato della sicurezza informatica
- Per la generazione di nuovi posti di lavoro

Ringraziamenti: Autori

Luca Albertini

Stefano Armenia

Roberto Baldoni

Fabio Battelli

Luca Boselli

Stefano Buschi

Alfredo Caputi

Salvatore Carrino

Francesco Ceccarelli

Ludovica Coletta

Romina Colciago

Cosimo Comella

Fabrizio d'Amore

Ciro Di Carluccio

Rita Forsi

Luisa Franchina

Corrado Giustozzi

Davide Grassano

Michele Kidane Mariam

Alberto Marchetti Spaccamela

Carlo Mauceli

Antonino Mazzeo

Fabio Merello

Guido Milana

Luca Montanari

Paolo Prinetto

Leonardo Querzoni

Alfio Rapisarda

Andrea Rigoni

Massimo Rocca

Valeria Risuglia

Lorenzo Russo

Federico Ruzzi

Mario Terranova

Toto Zammataro

Andrea Zapparoli Manzoni

CYBER INTELLIGENCE AND INFORMATION SECURITY CENTER

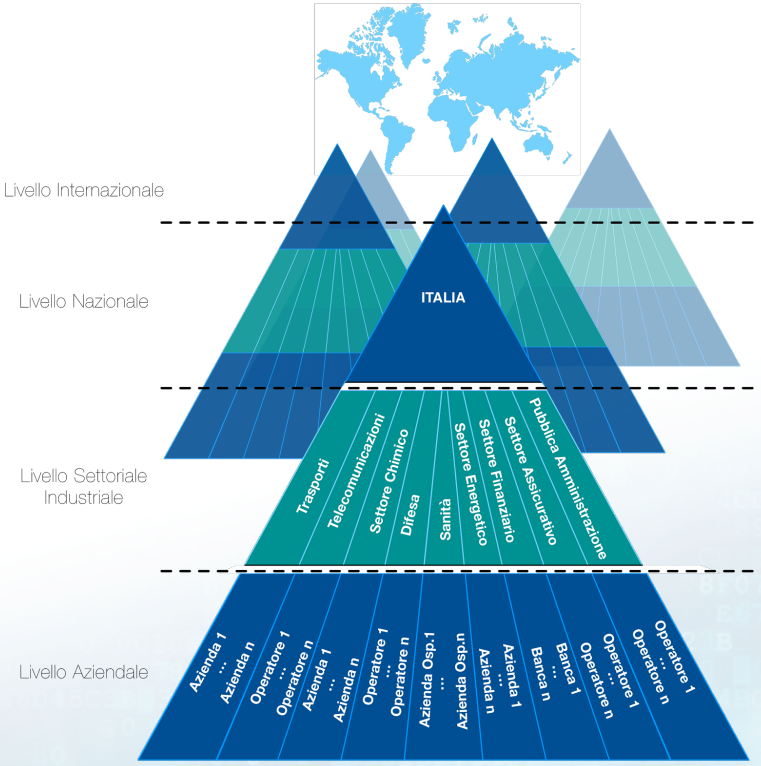
SAPIENZA UNIVERSITÀ DI ROMA

cini Cyber Security National Lab

Ringraziamenti

- Coloro che hanno partecipato alla revisione nella consultazione pubblica
- Società che hanno supportato questo evento

Come aggiornare il framework



- Documento vivo
- Chiediamo endorsment governativo
- Pillar Italiano nelle relazioni internazionali